

Mejora de Arquitectura (TO-BE) — Identificación y Priorización de Mejoras

Cliente

Vicerrectoría de Desarrollo — Universidad de La Sabana

Integrantes del equipo

- Julián David Aguilar
 - Juan Esteban Ramirez
-

1. Diagnóstico inicial

Fricción operativa

El proceso actual de programación y ejecución de encuestas de satisfacción depende de un flujo semi-manual. Aunque en el Taller 3 se modelaron tres flujos en Power Automate (Cruce de Horarios, Notificación a Profesores, Distribución y Registro de Encuestas), persiste una elevada fricción en la confirmación de disponibilidad con los docentes y en el agendamiento espacial. Las respuestas de aceptación o rechazo por parte de los profesores son procesadas de manera diferida por correo electrónico, lo que genera retrasos prolongados en la fijación de fechas de encuesta.

Problemas recurrentes señalados por el cliente

1. **Baja tasa de respuesta y tardanza en la recolección:** La notificación tardía y los enlaces genéricos por correo electrónico provocan desinterés en los estudiantes seleccionados (muestra PAT).
2. **Re-procesamiento por rechazo de profesores:** Cuando un docente no acepta ceder su espacio lectivo, el coordinador debe reiniciar manualmente el cruce de disponibilidad en SIGA y reprogramar la encuesta.
3. **Limitaciones de concurrencia y escalabilidad en la persistencia:** El uso de SharePoint Lists y archivos Excel como almacén de datos (Taller 4) genera cuellos de botella durante las fases pico de aplicación de encuestas, afectando la velocidad de registro e integridad de los datos.

Vulnerabilidades de seguridad y riesgos (Talleres 4 y 5 - STRIDE)

Basados en el análisis STRIDE realizado en el Taller 5 para la Universidad de La Sabana:

- **T1 - Exposición del Repositorio de Datos (Information Disclosure):** Almacenar información de estudiantes, profesores y resultados de encuestas en SharePoint Lists sin un esquema estricto de Control de Acceso Basado en Roles (RBAC) o encriptación granular expone datos sensibles protegidos por la Ley 1581 de 2012 (Habeas Data).
- **T2 - Suplantación de la Cuenta de Servicio (Spoofing / Elevation):** La ejecución de los flujos de Power Automate mediante cuentas de usuario o de servicio compartidas sin Autenticación Multi-Factor (MFA) ni principio de mínimo privilegio expone al sistema a suplantación de identidad.
- **T6 - Exfiltración de Datos por Conectores (Elevation of Privilege / Exfiltration):** Ausencia de políticas de Prevención de Pérdida de Datos (DLP) en la entidad tenant de Power Platform, lo que permitiría desviar la información a servicios externos no autorizados.

Resumen del problema actual (Foto del AS-IS)

El sistema actual en alcance está fragmentado en herramientas de bajo código (Power Automate, SharePoint Lists, Excel) con acoplamiento a procesos manuales de validación. Carece de mecanismos de seguridad avanzada para protección de datos personales (Ley 1581/2012), utiliza esquemas de persistencia no diseñados para alta concurrencia y genera demoras acumuladas en la acreditación institucional debido al ciclo lento de confirmación con los profesores.

2. Propuesta de mejoras

2.1 Lluvia de ideas (sin censura inicial)

#	Idea de mejora	Tipo
1	Integración por API REST síncrona con SIGA y envío de Tarjetas Adaptativas (Adaptive Cards) en Outlook/Teams para confirmación con 1-click por parte de docentes.	Proceso / Tecnología
2	Migración del almacenamiento desde SharePoint Lists a Microsoft Dataverse / Azure SQL Database con encriptación TDE y RBAC granular.	Tecnología / Seguridad
3	Configuración e implementación de Políticas de Prevención de Pérdida de Datos (DLP) en el tenant de Power Platform.	Seguridad / Normatividad
4	Sustitución de cuentas de servicio compartidas por Identidades Administradas (Azure Managed Identities / Service Principals) con MFA y Acceso Condicional.	Seguridad
5	Automatización de recordatorios inteligentes con lógica predictiva basada en la fecha límite de la encuesta.	Proceso
6	Rediseño del formulario en Microsoft Forms / Power Apps con autenticación SSO y generación de tokens de respuesta única de solo un uso.	Tecnología / Seguridad

2.2 Priorización (2-3 soluciones priorizadas)

Solución priorizada	Esfuerzo Impacto	Quick win / Largo plazo	Justificación
---------------------	------------------	-------------------------	---------------

Solución priorizada	Esfuerzo Impacto		Quick win / Largo plazo	Justificación
Solución A: Implementación de Tarjetas Adaptativas (Adaptive Cards en Outlook/Teams) + Integración API con SIGA para confirmación docente en 1-click.	Medio	Alto	Quick Win	Elimina el principal cuello de botella operativo del proceso al permitir que el docente acepte o rechace ceder su espacio de clase directamente desde la notificación sin cambiar de ventana, automatizando la reprogramación en tiempo real.
Solución B: Migración a Microsoft Dataverse / Azure SQL con RBAC estricto y configuración de Políticas DLP en Power Platform.	Medio	Alto	Quick Win	Resuelve de manera inmediata las vulnerabilidades T1 y T6 de STRIDE (Taller 5) y garantiza el cumplimiento normativo con la Ley 1581 de 2012, asegurando los datos personales de estudiantes y profesores contra accesos no autorizados y exfiltración.
Solución C: Transición a Service Principals (Azure Active Directory / Entra ID) y uso de Tokens de Respuesta Única para estudiantes.	Alto	Alto	Largo plazo	Elimina los riesgos de suplantación de identidad (T2) en la automatización y previene el fraude o llenado múltiple de encuestas, elevando la confiabilidad de los datos de acreditación.

3. Visualización TO-BE

3.1 Proceso mejorado

En la arquitectura TO-BE, el proceso se transforma de la siguiente manera:

1. El **Coordinador** configura los parámetros en el Panel de Coordinación.
2. El **Flujo de Cruce de Horarios** consulta mediante API REST el sistema **SIGA**, valida disponibilidades de aulas/estudiantes PAT de manera automática e invoca el envío de la encuesta.
3. El docente recibe una **Tarjeta Adaptativa (Adaptive Card)** en Microsoft Teams y Outlook. Al hacer clic en "Aceptar", el flujo agenda la encuesta instantáneamente. Si selecciona "Rechazar", el sistema busca automáticamente la siguiente mejor alternativa horaria en SIGA.
4. El estudiante recibe un enlace individual respaldado por token único vía **Microsoft Forms con Azure AD SSO**, registrando la respuesta de forma cifrada.

3.2 Cambios en aplicaciones, infraestructura y flujos de información

- **Contenedor de Persistencia:** Se reemplaza SharePoint Lists por **Microsoft Dataverse / Azure SQL Database**.
- **Canal de Interacción con Docentes:** Incorporación de **Adaptive Cards (Actionable Messages)** sobre Outlook y Teams.
- **Gestión de Identidades:** Reemplazo de credenciales compartidas por **Service Principals en Azure Entra ID**.

- **Flujo de Integración SIGA:** Creación de un conector personalizado seguro (Custom Connector con OAuth 2.0) hacia las APIs de SIGA.

Anexos del modelo:

- Diagrama C2 TO-BE de Aplicaciones: `entrega/to-be-aplicaciones-final.drawio`
- Mapa TO-BE de Tecnología e Infraestructura: `entrega/to-be-tecnologia-final.drawio`

3.3 Controles de seguridad integrados (Mitigación STRIDE - Taller 5)

1. **Mitigación T1 (Information Disclosure):** Encriptación en tránsito (TLS 1.3) y en reposo (AES-256 / TDE) en Dataverse. Asignación de roles de acceso restringidos por unidad organizacional.
2. **Mitigación T2 (Spoofing):** Autenticación vía Entra ID (Azure AD) con políticas de Acceso Condicional y Service Principals sin intervención de credenciales de usuario.
3. **Mitigación T6 (Elevation of Privilege / Exfiltration):** Aplicación de Políticas DLP a nivel de entorno en Power Platform, bloqueando conectores no empresariales (como Google Drive, Dropbox, HTTP no autenticado).

4. Análisis de beneficios y riesgos

Mejora / Solución	Beneficio de negocio	Beneficio tecnológico/seguridad	Riesgo, limitación o dependencia de implementación
Tarjetas Adaptativas (Adaptive Cards) + API SIGA	Reducción del tiempo de programación de semanas a horas; incremento en el cumplimiento de encuestas.	Eliminación de correos no estructurados y automatización síncrona de eventos de agendamiento.	Dependencia de la disponibilidad y tiempo de respuesta de las APIs de SIGA desarrolladas por la Universidad.
Dataverse / Azure SQL + Políticas DLP	Garantía de cumplimiento legal (Ley 1581 de 2012) ante auditorías y protección de reputación institucional.	Eliminación de vulnerabilidades T1 y T6 de STRIDE; almacenamiento escalable de alta concurrencia.	Costo adicional de licenciamiento (Dataverse / Azure SQL) dentro del tenant de la universidad.
Service Principals + Tokens Únicos (Entra ID)	Elevada validez de la información recolectada para los procesos institucionales de acreditación.	Eliminación de la suplantación de identidades (T2); trazabilidad y auditoría completa en Azure Logs.	Requiere permisos de administración global de Entra ID para la creación y gestión de App Registrations.

Anexos

- **Diagrama TO-BE de Aplicaciones:** `entrega/to-be-aplicaciones-final.drawio`
- **Diagrama TO-BE de Tecnología:** `entrega/to-be-tecnologia-final.drawio`
- **Matriz de brechas (Gap Analysis):** `entrega/matriz-brechas.xlsx`